

GIJO AS — 제품 소개 자료 (v5.15.0)

한 명의 보안담당자가 여러 명 몫을 해내도록. 쏟아지는 보안 정보를 AI 에이전트가 **자동으로 엮어** 처리하는 온프레미스 보안 운영 플랫폼.

*본 자료의 모든 수치·예시·스크린샷은 실제 구동해 뽑은 **실측 백데이터**입니다(서버 자동화 시험 **3,010개+** 통과 · 실패 0, 2026-08-10).* 스크린샷은 실제 제품 화면(HTML/CSS)을 실측 서버 응답으로 렌더링한 것입니다 — 목업이 아닙니다. ([screenshots/](#) 폴더)

1. 왜 필요한가 — 보안담당자의 현실

기업 보안담당자는 늘 인원이 부족합니다. 그런데 처리해야 할 일과 받는 정보는 계속 늘어납니다.

현실의 고충	무엇이 힘든가
보안제품 운영·관리	패치·메뉴 확인·장애 대응·발견 문제 전달을 사람이 일일이 추적
쏟아지는 보안 정보	제품 로그, CTI(위협 인텔), 취약점 스캔 결과가 따로따로 도착
정보 간 대조가 수작업	"이 위협이 우리 어느 자산에?", "이 자산 문제가 어느 서비스에?"를 눈으로 매칭
반복되는 보고	임원·팀장 보고서, KPI를 매번 손으로 취합
AI 보안까지 추가	이제 AI 모델 자산·공급망까지 관리 대상

핵심 문제. 개별 데이터는 다 있습니다. 서로 연결이 안 되어 있을 뿐이고, 그 연결을 담당자가 머리로 대신하고 있습니다.

2. GIJO AS 한 줄 정의

보안에 특화된 Agent AI 팀이 로컬 LLM으로 담당자의 업무를 대신합니다. 따로 놀던 보안 정보를 스스로 이어 붙여 "지금 무엇이 위험한지"를 바로 보여줍니다. 데이터도 AI도 폐쇄망(온프레미스) 안에서만 돌립니다. 밖으로 나가는 것이 없습니다.

3. 핵심 가치 3가지

① 자동 상관관계 — "정보를 엮어주는" 레이어

개별 사일로(자산·CTI·점검·컴플라이언스)를 자동으로 연결합니다.

CTI 위협 → 영향받는 내부 자산 → 영향받는 업무 서비스
스캔 취약점 → 승인 검토 → SBOM 반영

② 온프레미스 Agent AI — 데이터 주권

8종 보안 에이전트가 로컬 GPU의 LLM으로 작동. 외부 API·클라우드 없이 폐쇄망 완결.

③ 지속 학습 거버넌스 — 쓸수록 똑똑해짐

RAG(장기 기억) + 헤르메스 폐쇄형 학습 루프로 실제 대화를 학습에 반영. 점검·승인은 감사 추적으로 관리.

4. 주요 기능 (업무 중심)

4.1 🤖 에이전트 AI 팀 + 복합 지시

목적: 자연어로 지시하면 보안 에이전트 팀이 알아서 협업 처리.

8종 고정 에이전트(실측):

에이전트	역할	쓰는 모델
오케스트레이터	작업 분배·결과 취합	기반 모델
스캔	정적분석 실행 (ModelScan)	기반 모델
침투테스트	익스플로잇 검증	기반 모델
분석	우선순위 판단·설명	기반 모델 + 취약점 어댑터
SBOM	SBOM 생성·정리	기반 모델
CTI	딥웹·다크웹 감시	기반 모델
리포트	내부 보고서 작성	기반 모델
모델 진화	전문가 어댑터 학습·평가	기반 모델

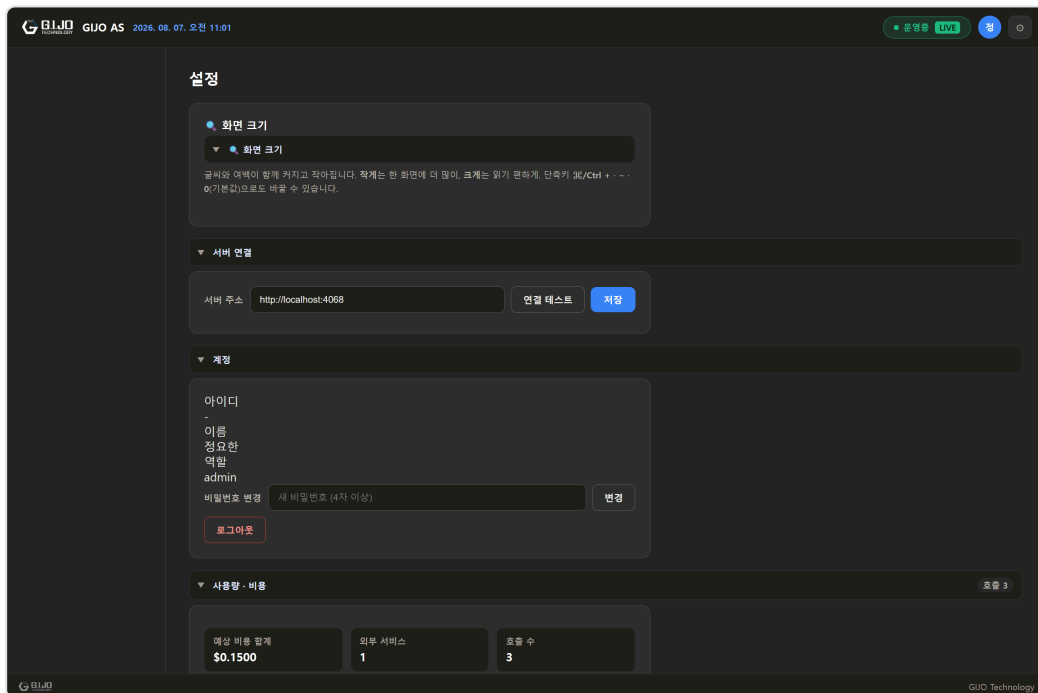
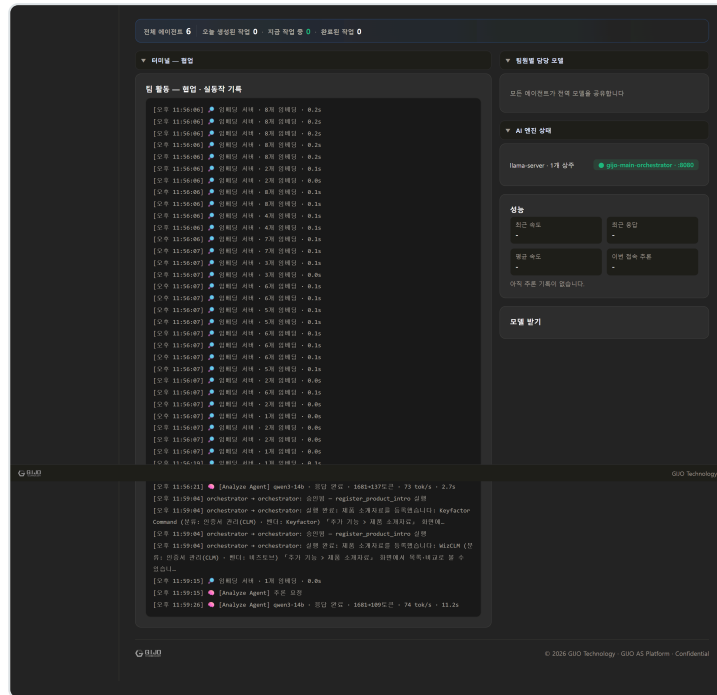
모델 구성. 기반 모델은 한 개(현재 배포 Qwen3-14B)이고 역할별 차이는 전문가 어댑터(LoRA)로 냅니다. 예전에는 역할마다 다른 7B 모델을 병렬로 띄웠습니다. GPU가 하나면 그 병렬이 실제로는 순차라 갈아 끼우는 비용만 커진다는 것을 실측으로 확인했습니다. 어댑터는 기반 모델 전체가 아니라 얇은 덧옷이라 메모리도 전환 시간도 훨씬 적게 듭니다.

고객이 **직접 고른 모델(BYOM)**을 올릴 수도 있습니다 — 올리면 제품이 문맥 길이·생각 과정 표시를 자동으로 맞춥니다. 모델마다 라이선스가 다르니 상업적 사용 가능 여부는 도입 전에 확인하세요.

복합 지시(오케스트레이션): 여러 작업을 한 문장으로.

실측 — 지시: "CTI 영향 자산 스캔하고 리포트까지" → 자동 계획: ① 스캔(대상=CTI 영향 자산 자동 해석) → ② 리포트 작성 (2단계 복합 실행)

각 단계는 협업 로그에 실시간으로 표시되고 스캔 결과가 그대로 리포트로 이어집니다.



4.2 🌟 CTI ↔ 내부 자산 자동 매칭 (핵심 차별점)

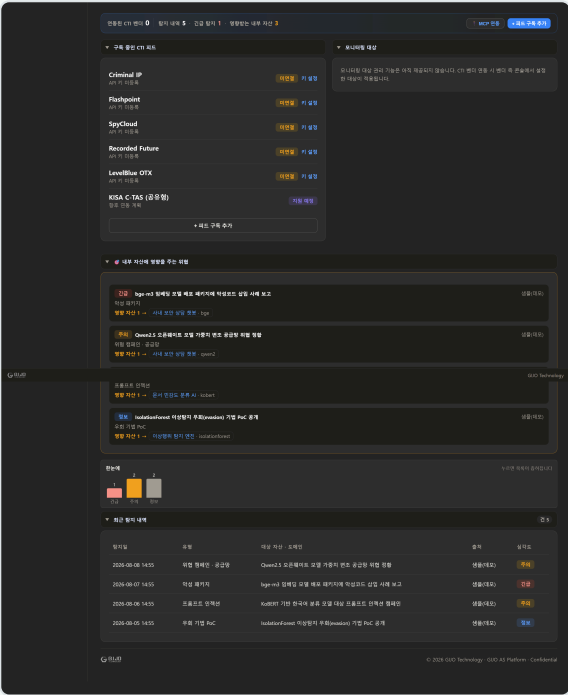
목적: "이 위협이 우리 어느 자산에 영향?"을 자동으로.

CTI 위협의 대상 텍스트를 자산의 구체적 식별자(컴포넌트·CVE·모델명)와 대조합니다.

실측 — 수집 위협 5건 중 4건이 자산에 매칭, 영향 자산 3곳:

위협 (target)	심각도	→ 영향 자산	매칭 근거
Qwen2.5 오픈웨이트 모델 가중치 변조 공급망 위협	주의	사내 보안 상담 챗봇	qwen2
bge-m3 임베딩 배포 패키지 악성코드 삽입	긴급	사내 보안 상담 챗봇	bge
KoBERT 분류 모델 대상 프롬프트 인젝션 캠페인	주의	문서 민감도 분류 AI	kobert
IsolationForest 이상탐지 우회 PoC 공개	정보	이상행위 탐지 엔진	isolationforest
(다크웹 계정 유출 — 무관)	정보	(매칭 없음, 정상 제외)	—

담당자의 눈 대조 작업을 없앴. 무관한 위협은 오탐 없이 걸러냄.



4.3 서비스 영향도 — 자산 → 업무 서비스

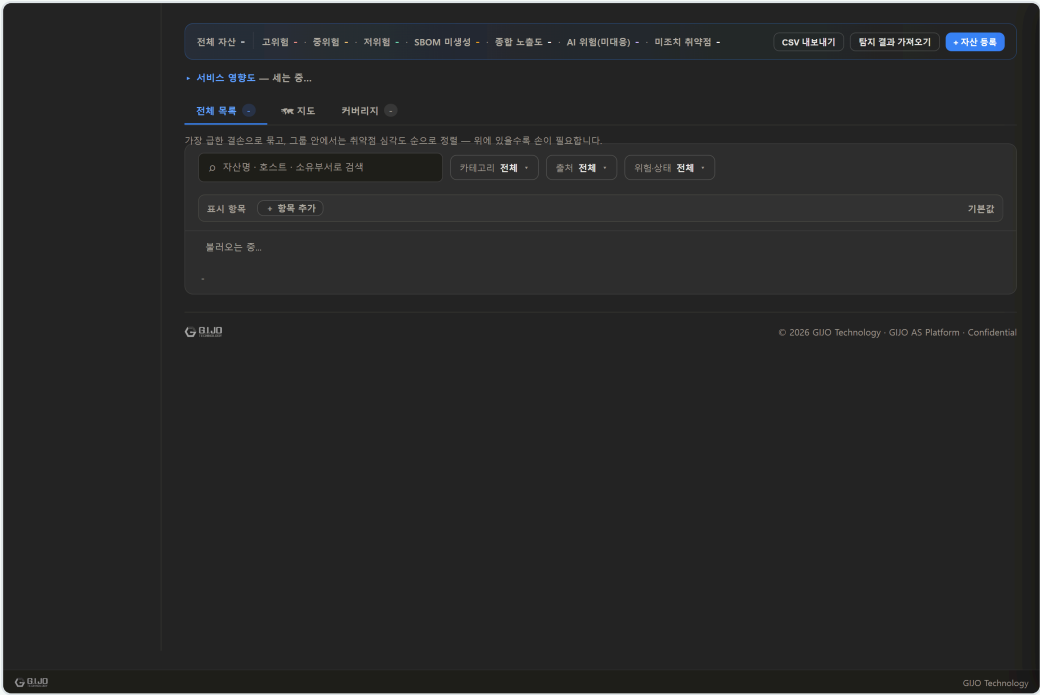
목적: "이 자산/보안제품 문제가 어느 업무 서비스에 영향?"을 자동으로.

자산을 업무 서비스로 묶어 위험(자산 취약점·CTI 위협·지연 점검)을 롤업합니다.

실측 — 서비스 3곳 모두 CTI 위협으로 "영향도 높음":

서비스	자산	영향도	위험 요인
임직원 보안 포털	사내 보안 상담 챗봇	높음	CTI 위협 1
문서관리 시스템	문서 민감도 분류 AI	높음	CTI 위협 1
SOC 관제 플랫폼	이상행위 탐지 엔진	높음	CTI 위협 1

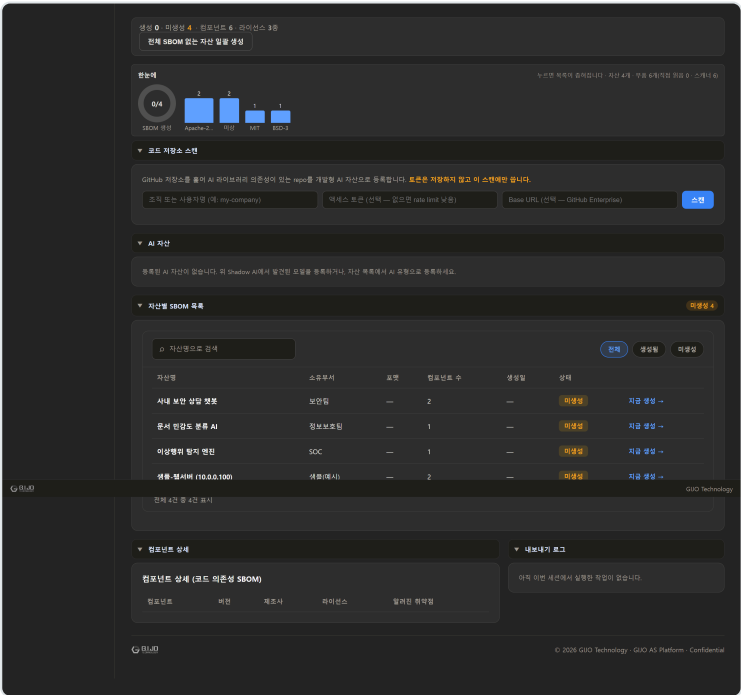
위협 → 자산 → 서비스까지 한 번에 연결. "지금 위험한 서비스"를 임원에게 바로 설명.



4.4 📦 자산 인벤토리 · AI-BOM · SBOM

목적: AI 자산뿐 아니라 받는 다양한 정보를 구성명세로 관리하고 취약점을 빠르게 확인.

- 자산 인벤토리: AI 자산 + 일반 IT 자산(Nessus 업로드), 컴포넌트·소유부서·지원 서비스
- AI-BOM: 모델·데이터·프롬프트·도구·인프라 5영역 명세
- SBOM 내보내기: CycloneDX 및 SPDX-2.3 표준 지원

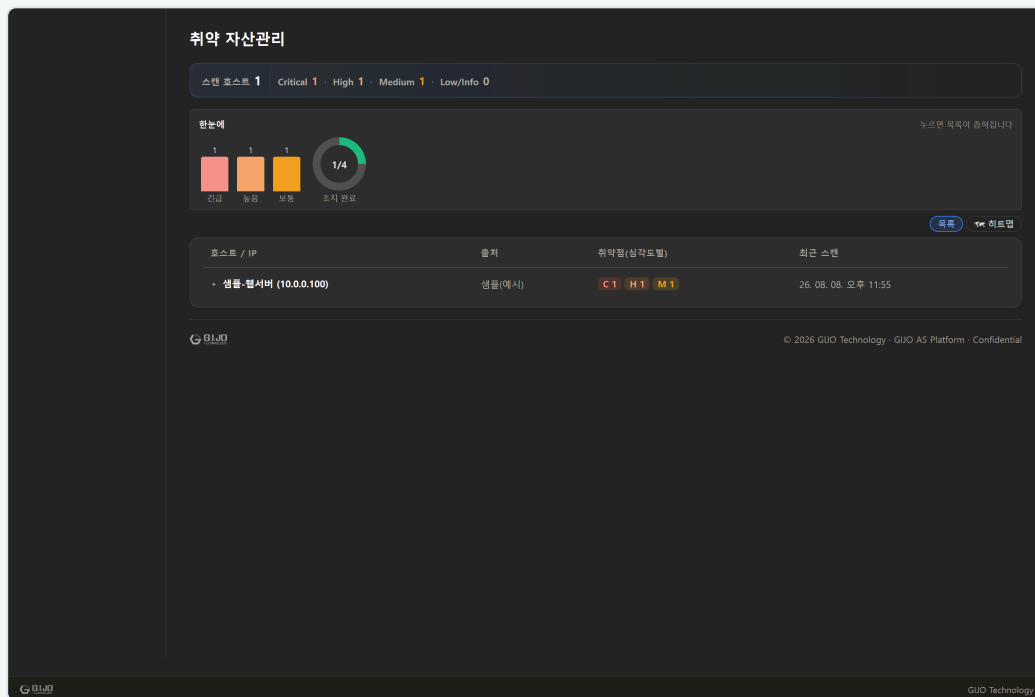


4.5 🛡️ 취약점 생애주기 관리 (Nessus)

목적: 취약점을 "목록"이 아니라 **발견** → **우선순위** → **조치** → **측정** 생애주기로 관리(Tenable 방법론 채택).

- **임포트**: Nessus .nessus (원본 XML) · CSV · HTML 리포트를 그대로 업로드. **플러그인 단위로 중복 제거**(1,171행 → 282건), 호스트 정보(OS·DNS)·EPSS·VPR·**CISA KEV** 자동 인식
- **우선순위**: CVSS 심각도에 더해 실제 악용확률(EPSS)·KEV로 정렬 — "Medium인데 악용 94%"를 놓치지 않음
- **상태 추적**: 재스캔 대비 New/Active/**Fixed**/Resurfaced 자동 판정. 인증(credentialed) 스캔 여부로 "**Fixed 검증 신뢰도**"까지 표시
- **조치**: 취약점을 담당자·**SLA**(KEV 7일 / Critical 14일 / High 30일...) 붙은 조치 항목으로 전환
- **측정**: 실제 스캔 이력에서 재구성한 **변다운**으로 위험 감소 추적

실측 — 샘플 취약 호스트 1대: **Log4Shell**(Critical · CISA KEV 실제 악용) · OpenSSH(High) · Oracle 패치누락 (Medium · 악용확률↑) · SSL(**Fixed**로 검증) — 심각도·KEV·상태를 한눈에. 실 Nessus 리포트는 **1,171행을 282개 플러그인으로 중복 제거**하는 것도 실데이터로 검증했습니다.

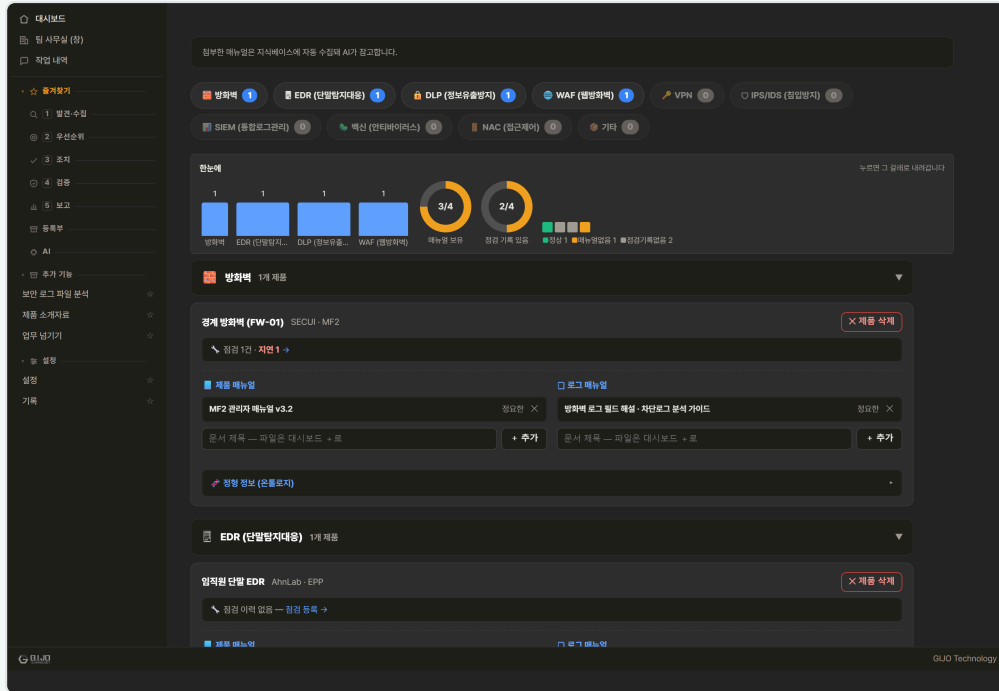


4.6 📁 보안제품 관리 (종류별 + 매뉴얼)

목적: 운영 중인 보안제품을 **종류별로 등록**하고, 제품 매뉴얼을 **AI가 학습**해 오케스트레이터가 참고.

- **종류별 등록**: 방화벽·EDR·DLP·WAF·VPN·IPS·SIEM·백신·NAC 카탈로그로 구분 관리, 대시보드에서 한눈에
- **매뉴얼 일괄 업로드**: 파일만 올리면 파일명으로 어느 제품 문서인지 자동 매칭(없으면 제품 자동 등록), 로그 관련 파일은 로그 매뉴얼로 자동 분류
- **AI 학습(RAG)**: 첨부한 매뉴얼은 지식베이스에 자동 수집 → "올린 문서 검색"과 **오케스트레이터 답변에 즉시 반영**
- **점검 연결**: 유지보수 점검과 제품을 이름 매칭으로 연결 → 제품 카드에서 점검 현황(지연·승인대기·다음 점검일) 확인

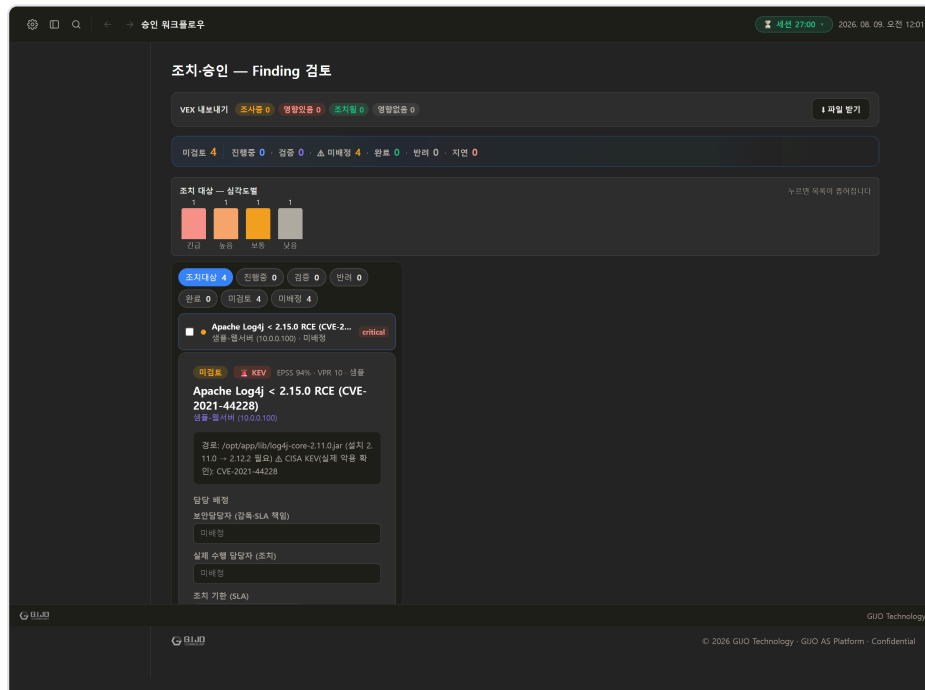
실측 — 4종 제품(방화벽·EDR·DLP·WAF) + 제품/로그 매뉴얼을 종류별 그룹으로 관리.



4.7 취약점 승인 워크플로우 (거버넌스)

목적: 스캔 finding을 검토해 확정/오탐 처리 → SBOM 반영 게이트.

담당자가 finding을 승인(확정) 또는 반려(오탐) 처리. 반려된 오탐은 SBOM 취약점에서 자동 제외. finding 내용 해시로 상태를 저장해 재스캔 후에도 검토 결과 유지.



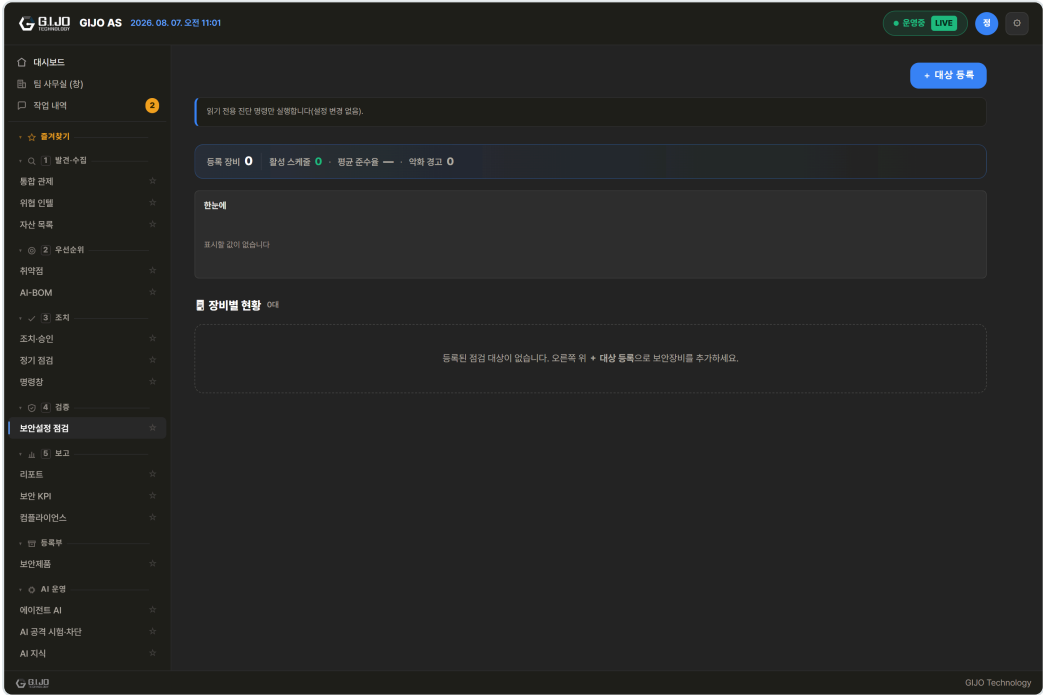
4.8 보안제품 운영 가이드 (유지보수 거버넌스)

목적: 패치·메뉴 확인·장애 대응을 일정→보고→승인 거버넌스로.

- **지식베이스:** 매뉴얼·에러로그(.log) 업로드 → RAG 검색으로 메뉴 확인·장애처리
- **점검 거버넌스:** 일정 등록 → 결과 보고 → 관리자 승인/반려 (반복주기 자동 생성)
- **이력 타임라인 + 이메일 알림:** 지연 점검을 담당자에게 자동 통지

실측 — 점검 6건(전 상태 시연):

점검	대상	상태
방화벽 정책 정기 점검	경계 방화벽(FW-01)	예정(오늘 마감)
프론트트 가드레일 점검	보안 상담 챗봇	승인 대기
학습데이터 접근권한 점검	문서 민감도 분류 AI	승인됨
오탐 룰 점검	이상행위 탐지 엔진	반려
WAF 룰셋 점검	웹방화벽(WAF-01)	승인됨
VPN 게이트웨이 인증서 점검	VPN 게이트웨이(VPN-03)	예정

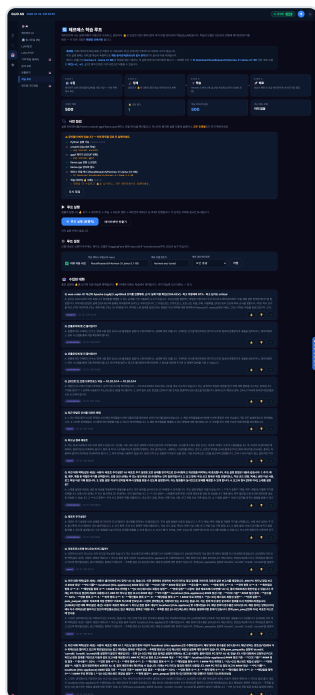


4.9 로컬 LLM · RAG · 전문가 어댑터 학습 (2026-08 재설계)

목적: 온프레미스 AI로 연속성 유지, **우리 현장에서 쌓인 문답으로** 분야별 전문가를 길러냄.

- **로컬 LLM:** llama.cpp 멀티모델 풀(RTX 3090), 팀원(에이전트)별 모델 배정. 고객이 원하는 모델을 가져다 쓸 수 있고 (BYOM), 모델마다 다른 버릇은 제품이 자동으로 맞춥니다(생각 모드·문맥 길이).
- **RAG(장기 기억):** 사내 문서를 LanceDB에 넣어 검색·근거 주입. **읽을 수 없는 문서는 넣는 순간 막습니다**(2026-08 관문 신설 — 아래 6.5).
- **전문가 어댑터(LoRA):** 「베이스 1개 + 어댑터 N개」 구조. 주제(취약점·장비운영·사내규정·위협대응)별로 승인된 문답이 **300건을** 넘으면 그 주제 어댑터를 학습합니다.

- **등록 ≠ 채택**: 학습된 어댑터는 *미채택* 상태로 등록됩니다. 평가 게이트와 A/B를 통과하고 사람이 채택해야 실제 답변에 실립니다. 실제로 1호 어댑터는 품질이 모자라 채택하지 않았습니다.
- 밖에서 받은 어댑터도 대화창 지시 → 결재판 승인으로 반입할 수 있습니다(무결성 검사 포함).
- **학습 자료 위생**: 배포·검증 계정의 대화는 후보에서 **자동 제외**됩니다 — 제품이 아니라 시험을 배우면 안 되기 때문입니다.



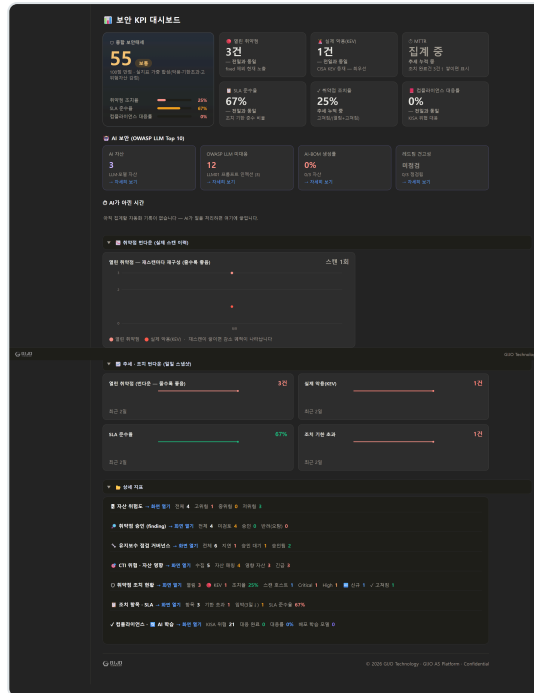
4.10 🇰🇷 통합 보안 KPI 대시보드

목적: 흩어진 지표를 한곳에 + 매일 스냅샷으로 추세 → 임원 보고·방향성 결정.

번다운·SLA 준수율·KEV 추세까지 한 화면에 모읍니다.

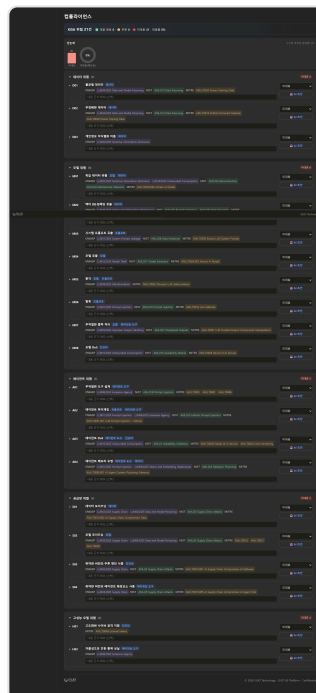
실측 — 통합 스냅샷(2026-07-17):

도메인	지표
취약점(Nessus)	열린 3 · Critical 1 (Log4Shell) · KEV 1 · 번다운 추세
자산	전체 4 (AI 자산 3 + 취약점 스캔 호스트 1)
유지보수 점검	전체 6 · 지연 1 · 승인대기 1 · 승인 2 · 반려 1
CTI 자산영향	수집 5 · 자산매칭 4 · 영향 자산 3 · 긴급 3
컴플라이언스	KISA 위협 21항목 · 대응률 집계
AI 학습	배포 모델 0 (학습 실행 시 누적)



4.11 📄 임원/팀장 보고서

목적: KPI·점검 거버넌스·자산 상세를 담은 docx 보고서를 자동 생성 + 이메일 발송. 경영진 요약은 로컬 LLM이 작성, 유지보수 거버넌스 섹션(승인/반려 감사 추적) 포함.



4.12 🛡️ 보안장비 하드닝 점검 · 원격 정기점검 (신규)

목적: 방화벽·서버 등 보안장비의 설정 취약점을 국내 CCE(KISA 주요정보통신기반시설 U-시리즈)+CIS 기준으로 점검.

- 챗봇 명령("○○ 하드닝 점검해줘") 또는 담당자 PC 터미널(CLI — 허용목록·승인·위험차단)로 즉시 실행 → 분류별 리포트.
- 원격 정기점검: SSH로 대상을 등록해 스케줄 자동 점검·이력·악화 알림(관제 대시보드). 결과는 통합 관제(보안 분석)의 4번째 소스로 상관분석에 합류.

4.13 🚧 MCP 연동 — AI를 외부 도구에 안전하게 연결 (신규)

목적: AI 에이전트를 외부 도구·데이터(위협 인텔·스캐너·티켓·SIEM)에 MCP(Model Context Protocol)로 표준 연결.

- 온프레임 원칙: 기본 OFF·관리자 게이팅, 외부로 데이터가 나가는 원격 서버는 egress 승인해야 활성, 에이전트×도구 허용 매트릭스, 호출 감사.
- 전송 stdio(로컬)/Streamable HTTP(원격). 위협 인텔리전스(CTI) 소스 연결이 대표 사례. 경쟁 SaaS 대비 "데이터 주권을 지키면서 확장"하는 차별점.

4.14 📍 어디서든 지시·작업 기록(감사) (신규)

목적: 대시보드가 아닌 어느 화면에서도 오른쪽 **■ 작업 화면** 탭으로 지휘 콘솔을 열어 AI에게 자연어로 지시(현재 화면 맥락 자동 전달). 모든 실행·승인·차단·변경은 작업 기록(감사 로그) 단일 타임라인에 남아 추적됩니다.

4.15 📁 메뉴가 곧 업무 순서 — 절차 5단계 허브 (2026-08)

목적: 메뉴를 데이터 창고가 아니라 일하는 순서로 세웁니다. 담당자가 취약점 한 바퀴를 도는 데 그룹 세 곳을 오가던 것을 없앴습니다.

- ① 발견·수집 → ② 우선순위 → ③ 조치 → ④ 검증 → ⑤ 보고 — 다섯 단계가 각각 허브 한 화면입니다. 허브 위쪽 띠에서 현황을 한눈에 보고, 판을 누르면 아래 무대에서 그 화면이 열립니다.
- 그 아래에 등록부(보안제품)·AI(팀·지식·학습·안전장치)·추가 기능·설정이 놓입니다.
- 지시는 대화창 한 곳에서만 받습니다 — 화면은 보여 주는 일만 합니다(오조작·이중 입구 방지).

4.16 📄 추가 기능 — 로그 분석·제품 소개자료·업무 넘기기 (2026-08)

- 보안 로그 파일 분석: 올린 로그 파일을 대장으로 쌓고, 그 로그에 등장한 내부 IP 중 아직 자산으로 등록되지 않은 것을 골라 체크 한 번으로 등록합니다. 이벤트 유형(브루트포스·포트스캔·차단 폭주·웹공격)에는 KISA 기준의 4단계 대응 절차가 붙습니다(모르는 유형에는 절차를 지어내지 않습니다).
- 제품 소개자료: 벤더 제품 소개서를 분류해 목록으로 쌓고 최대 3개까지 표로 비교합니다. 보안제품 매뉴얼과는 별도 대장이며, 처음 올릴 때 결재판으로 확인합니다. 근거가 없는 칸은 지어내지 않고 「—」로 둡니다.
- 업무 넘기기: 인수인계 문서를 근거 배치와 함께 자동 구성합니다.

4.17 🗑️ 입력 개인정보 가리기·에어갭 봉인 (2026-08)

- 개인정보 가리기: 담당자가 대화창에 붙여 넣은 주민등록번호·카드번호는 AI에 닿기 전에 가려집니다(생년월일·Luhn 검증으로 오탐 차단). 업무에 필요한 IP·호스트명은 건드리지 않습니다.
 - 에어갭 봉인: 스위치 하나로 내부를 뺀 모든 바깥 통신을 막습니다(기본은 차단입니다). 나갈 수 있는 통로는 목록으로 관리하고, 봉인 상태는 대화창에서 물어보면 됩니다.
-

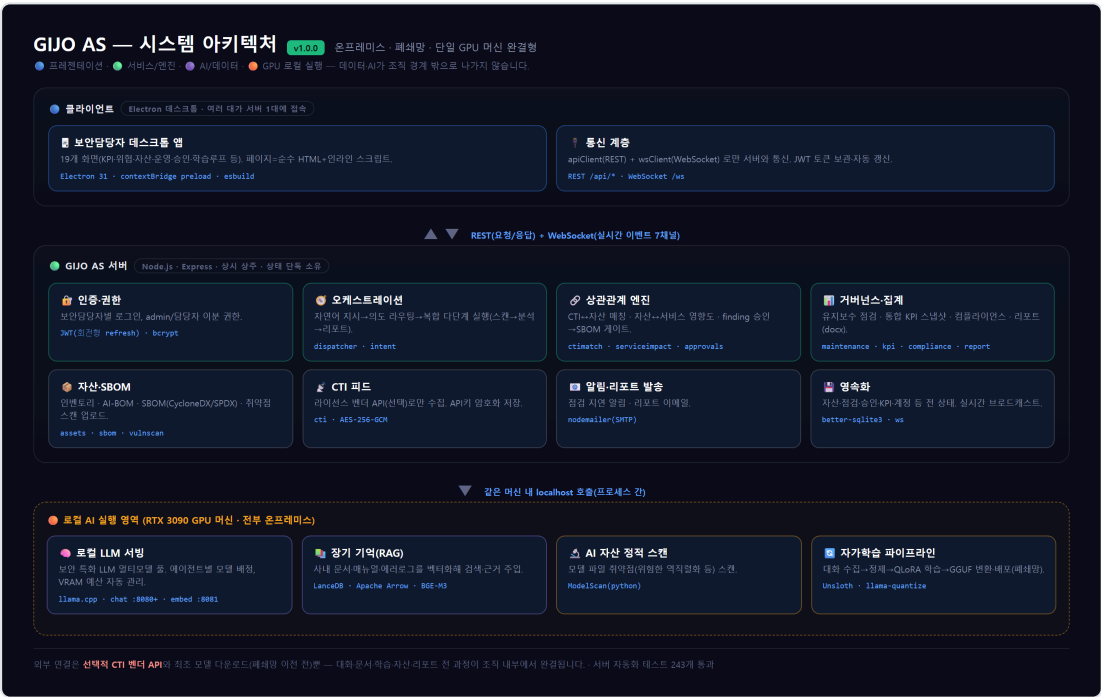
5. 한눈에 보는 상관관계 (백데이터 요약)

[샘플 CTI 위협 5건]	[내부 자산 3종]	[업무 서비스 3곳]
Qwen2.5 공급망 위협	—매칭(qwen2)—> 사내 보안 상담 챗봇	—> 임직원 보안 포털 [영향도 높음]
bge-m3 악성 패키지	—매칭(bge)—> 사내 보안 상담 챗봇	
KoBERT 프롬프트인젝션	—매칭(kobert)—> 문서 민감도 분류 AI	—> 문서관리 시스템 [영향도 높음]
IsolationForest 우회	—매칭(isol...)—> 이상행위 탐지 엔진	—> SOC 관제 플랫폼 [영향도 높음]
다크웹 계정 유출	—(무관, 제외)	

위협이 도착하면 영향 자산에서 영향 서비스까지 자동으로 이어집니다. 담당자는 "무엇부터"만 정하면 됩니다.

6. 아키텍처 및 적용 기술

6.1 시스템 구성 (한눈에)



3계층 · 단일 GPU 머신 완결형:



서버 1대가 모든 상태를 단독으로 갖고 여러 데스크톱 클라이언트가 REST/WebSocket으로 붙는 구조입니다. 서버와 AI, 데이터가 한 GPU 머신 안에서 끝나기 때문에 폐쇄망 배포에 잘 맞습니다.

6.2 적용 기술 스택 (레이어별)

레이어	기술	역할
클라이언트	Electron 31 · TypeScript · esbuild	데스크톱 앱. contextBridge preload로 안전한 API 표면만 노출
	apiClient(REST) · wsClient(WebSocket)	서버 통신 · 실시간 이벤트 수신
서버(웹)	Node.js · Express 4 · TypeScript	REST API + 앱 조립. ws 로 WebSocket 브로드캐스트
	JWT(jsonwebtoken) · bcryptjs	담당자별 로그인(회전형 refresh 토큰) · 비밀번호 해시
	better-sqlite3 (SQLite, WAL)	자산·점검·승인·KPI·계정 등 전 상태 영속화
	AES-256-GCM(cryptopack)	CTI/SMTP 비밀키 암호화 저장(평문 저장 안 함)
	@cyclonedx/cyclonedx-library	SBOM CycloneDX 1.5 생성
문서/표준	(직접 생성) SPDX-2.3 JSON	SBOM SPDX 내보내기
	docx	임원/팀장 리포트(.docx) 생성
	nodemailer(SMTP)	리포트·점검 지연 알림 이메일
	simple-git	리포지토리 스캔(자산 자동 등록)
	llama.cpp	로컬 LLM 서빙(채팅 :8080+ 멀티모델 풀, 임베딩 :8081)
	LanceDB · Apache Arrow	장기 기억(RAG) 벡터 저장·검색
	BGE-M3	임베딩 모델(RAG 검색용)
AI/데이터	ModelScan (python)	AI 모델 파일 정적 취약점 스캔
	transformers · peft · bitsandbytes	주제별 전문가 어댑터(QLoRA 4bit) 학습 — 학습 전용 환경에서 실행

레이어	기술	역할
	llama.cpp convert_lora_to_gguf · llama-quantize	학습 산출을 GGUF 어댑터로 변환·양자화
	pypdf / OWPML	문서(PDF·HWPX·에러로그) 텍스트 추출 — 인입 전 필수 관문
프로토콜	MCP(@modelcontextprotocol/sdk)	도구/에이전트 연동 표준

6.3 실시간 처리 — WebSocket 이벤트 채널(7종)

서버가 상태 변화를 모든 접속 클라이언트에 즉시 브로드캐스트합니다(폴링 없음): `collaboration:event` (에이전트 협업) · `llm:event` (추론 실행) · `asset:updated` (자산 갱신) · `finetune:progress` · `learnloop:progress` (학습 진행) · `hf-download:progress` (모델 다운로드) · `log:event` (서버 로그)

6.4 핵심 데이터 흐름

- 1. **복합 지시**: 자연어 → **입력 관문**(개인정보 가리기·가드레일) → 의도 라우팅(규칙 우선, 로컬 LLM 보조) → 다단계 실행 → 쓰기는 **결재판 승인 후** 실행 → 협업 로그 실시간 표출
- 2. **RAG**: 문서 → **글자 꺼내기(추출 관문)** → 청크·위생 판정 → **인입 품질 판정** → 임베딩(BGE-M3) → LanceDB → 검색(의미 +글자 두 갈래 합침) → 관련성 게이트 → 근거 주입
- 3. **어댑터 학습**: 대화 수집(SQLite) → 후보함(자동화 계정 제외) → 담당자 승인 → 주제 300건 도달 시 QLoRA 학습 → GGUF 어댑터 변환 → **미채택 등록** → 평가 게이트·A/B → 사람이 채택해야 서빙 반영
- 4. **상관관계**: CTI 위협 텍스트 ↔ 자산 식별자 토큰 매칭 → 영향 자산 → 서비스 영향도 롤업

6.5 지식이 오염되지 않게 하는 관문 (2026-08 신설)

지식 저장소는 넣을 때 지킵니다. 검색할 때 걸러 내는 것만으로는 이미 늦습니다.

관문	무엇을 막나	어긋나면 생기는 일
글자 꺼내기	PDF·한글·오피스 문서를 글자로 그냥 읽는 것	압축 바이트가 「지식」이 되어 검색 상위를 차지
조각 위생	사람이 읽을 수 없는 조각(제어문자·인코딩 덩어리)	근거 자리를 쓰레기가 밀어냄 → AI가 지어냄
인입 품질 판정	걸러 낸 뒤 남은 게 거의 없는 문서를 성공 처리	「지식 N조각」이라 건강해 보이는 착시
숨은 지시문 차단	밖에서 받은 문서에 심긴 조종 문장	문서 한 줄이 우리 AI의 행동을 바꿈

지식은 넣는 순간 지켜야 합니다. 읽을 수 없는 문서가 섞이면 조각 수만 늘어 지식이 풍부해 보입니다. 정작 검색은 그 쓰레기를 위로 올려 진짜 근거를 밀어냅니다. GIJO AS는 그런 문서가 들어오면 성공한 척하지 않고 그 자리에서 알립니다.

6.6 보안·배포 특성 (폐쇄망 설계)

항목	내용
데이터 주권	대화·문서·학습·자산·리포트 전 과정이 조직 내부에서 완결
외부 연결	선택적 CTI 벤더 API + 최초 모델 다운로드(폐쇄망 이전 전)뿐
GPU 조율	학습·병합 시 추론 엔진 자동 정지→재기동(단일 3090 VRAM 충돌 방지)
인증·권한	보안담당자별 로그인(JWT), admin/담당자 이분 권한
비밀정보	API키·SMTP 비밀번호 AES-256-GCM 암호화(평문 저장 안 함)
품질	서버 자동화 테스트 3,010개+ 통과 (284 파일 · WSL+Windows, 2026-08-10), 실기동 엔드투엔드 검증 + QA 전수조사 18계층

6.7 확장·운영

- **모델 자유 교체**: 추천 LLM 가이드에서 보안·학습·RAG·경량 모델을 용도별로 다운로드, 에이전트별 배정
- **자산 자동 유입**: Nessus `.nessus` /CSV/HTML 업로드 · Git 리포지토리 스캔으로 자산 자동 등록
- **보안제품·매뉴얼**: 종류별 제품 등록 + 매뉴얼 일괄 업로드(파일명 자동 분류·제품 자동 등록) → RAG 학습
- **모델 자산 관리**: AI-BOM 5영역(모델·데이터·프롬프트·도구·인프라) + SBOM 표준 내보내기
- **전문가 어댑터(LoRA)**: 기반 모델 하나에 주제별 어댑터를 갈아 끼워 역할을 나눔 — 평가 게이트·A/B 통과 후에만 채택 (모델 합성은 고급 옵션으로 보존)

7. 향후 계획 — 어디까지 왔고, 무엇을 할 것인가 (2026-08-10 기준)

모든 개발은 `GIJO_AS_시장경쟁력_전중후_계획서.md` (2026-07-29 제정)의 **전(단기)·중(중기)·후(장기)** 항목으로 관리됩니다. 아래는 그 계획의 현재 상태입니다. 전략의 핵심은 한 문장입니다 — **기능 추가 경쟁이 아니라 증거 경쟁**: 국내 경쟁사가 전부 과제·파일럿 단계인 지금(시간의 창), "설치되어 돌아가는 레퍼런스"를 먼저 만듭니다.

7.1 현재 위치 — 한 줄로

"파일럿 투입 가능 · GA 미판정" — 코드로 닫을 수 있는 GA 필수항목(PO) **9개 전부 실측 통과**. 남은 것은 코드 밖 관문 4개(외부 모의해킹 · 법무 검토 · 실사용 4주 · 인증)뿐입니다. 근거: `GIJO_AS_GA_판정표.md` (2026-08-10 재실측)

7.2 최근 완료 (2026-08 첫 주 ~ 10일)

완료한 것	내용
클라 5.15.0 게시	첫 설치 계정 화면(고객이 터미널 없이 시작) · 저장 암호화 화면 버튼 · 권장 모델 원클릭 받기 (검색 대신 검증된 목록 — 개조본 노출 차단)

완료한 것	내용
평가 게이트 기준선 확정	라우팅 66/66 · 안전 9/9 · 한국어 24/24 · 흔들림 0 — 코드를 바꿀 때마다 재실행, 통과 없이는 반영 금지
실전 상황 시험 확대	152상황 151/152 · 내용 기대표 149문항(커버리지 100%) · 매일 밤 자동 재측정 (회귀 즉시 탐지)
서버 시험 환경 정합	「제품이 도는 환경(WSL)에서 켜다」 확립 — 자동 시험 3,010개+ 통과·실패 0 , 전체 27초
에어갭 봉인	제품이 여는 외부 통로 9종 한 관문 차단 (기본 꺼짐 · 차단 시도는 기록에 남음)
AI 견고성	프롬프트 인젝션 14종 제품 경로 뚫림 0건 (입구 차단 13 · 모델 버팀 1)

7.3 단기 (전 단계, ~1개월) — "보여줄 수 있는 것" 만들기

#	할 일	상태·비고
전-1	4대 시나리오 시연 패키지 — 시나리오별 5분 대본 + 실화면, 특히 인수인계·규정 대조를 전면에	진행 중 (3소스 상관 「열쇠」 정합 설계안 2026-08-10 수립)
전-2	행동 대조 — "이거 해도 돼?" → 사내규정+법령 인용 ○/△/× 판정, 근거 없으면 "판단 불가"	진행 중 (레드팀 결과 조회 도구 등 반영)
전-3	학습 후보함 완성 — "쓸수록 똑똑해지는 제품"의 첫 조각	진행 중
전-4	기본 지식 번들 v1 — 6대 표준+지식 시드에 버전을 붙여 오프라인 갱신 배포	진행 중
전-5	파일럿 1곳 확보 (기밀등급·금융·방산 등 폐쇄망 유지 구간 우선)	사업 결정 — 모든 중기 계획의 전제
전-7	보여 주기(그림·첫인상·우리말) — 파트너 검토 의견 반영	아래 상세

전-7 상세 — 고객 의견 반영 6항목 (약 3주, `GIJO_AS_고객의견_반영계획_2026-08.md`):

- 1. **SBOM 패키지 수집** — 자산 구성요소가 OS·커널 23개뿐(CPE 수준)인 것을 `rpm --qa - dpkg --get-selections - Get-Package` 외가 전용 수집으로 실제 패키지 목록까지 보강 (기존 하드닝 경로 재사용, 23일)
- 2. **그림 3종** — 공격경로·4소스 상관·온톨로지를 자료에 그림으로 (있는 관계만 그림 — 지어내지 않음)
- 3. **첫 화면 단순화** + 한 줄/클릭 팝업
- 4. **취약점 한글 한 줄 확대** — 원문 이름은 보존(검색 열쇠), 그 아래 "무엇이 위험한가·무엇을 하면 되나" 한글 한 줄 (현재 4,833건 중 96%가 영문뿐)
- 5. **EOS/EOL 표 오프라인 번들** (지식 번들에 실어 배송)
- 6. 🚢 **표식 정리** — 코드가 결정적으로 낸 답에서는 떼고, AI가 쓴 문장에만 남김 (정직성)

7.4 중기 (~3개월) — 파일럿을 레퍼런스로

#	할 일	상태·비고
중-1	파일럿 실사용 피드백 루프 — 오답 지적은 회귀셋으로 흡수, 이탈 없는 4주가 목표	파일럿 확보 후
중-2	"AI가 아낀 시간" KPI — 임원 보고에 자동 포함	원형 가동 중(최근 30일 자동 처리 102건 ~ 45~56시간, 보수 추정)
중-3	평가 게이트 구축	✅ 가동 중 — 3축 기준선 확정(7.2절)
중-4	게이트 위에서 합성·학습 향상 — 후보합→데이터셋→튜닝→ 게이트 통과분만 배포	파이프라인 완성, 수요 확인 후 본격화
중-5	N2SF 대응 문서(등급별 배치 가이드)	초안 있음(GIJO_AS_N2SF_대응.md) — N2SF는 이제 차별점이 아니라 입장권
중-6	인증 준비 착수 검토(보안기능확인서·CC·GS)	사업 결정 (예산) — 파일럿 고객 요구 기준으로 선택
중-7	SIEM·장비 커넥터 확대 + SBOM 패키지 수집·EOS 표	파일럿 고객 실제 장비 우선
중-8	경쟁 동향 분기 재조사 (샌드랩 SANDY·이글루 AiR·SentinelOne 온프레임)	다음: 2026-10

7.5 장기 (6~12개월) — 제품을 사업으로

#	할 일	비고
후-1	GA 판정 — 남은 관문은 전부 코드 밖: 외부 모의해킹 · 법무 검토 · 실사용 4주 · 인증	코드 PO 9/9는 이미 닫힘
후-2	인증 취득 완료	공공·금융 조달 자격
후-3	기본 지식 번들 구독화 — 표준·위협·법령 번들 연 단위 갱신 상품(오프라인 배송)	일회성 라이선스에 반복 매출 축 추가
후-4	에어갭 에디션 — N2SF 기밀 등급·방산 타깃	봉인 관문은 이미 구현(7.2절) — 에디션화가 남음
후-5	채널 구축 — 보안 SI·관제사 파트너	1인 개발·직판의 한계를 넘는 길
후-6	해자 강화 — 인수인계 이력·오탐 족보·규정 매핑 등 고객별 축적 자산	기능은 베껴도 축적된 데이터 는 못 베낌

7.6 결정 대기 (2026-08-10 기준)

결정할 것	내용	왜 중요한가
고객 기계 실행환경	① LLM 엔진(llama-server) 동봉 — CPU 엔진은 4MB(설치본 +0.6%), GPU 런타임(CUDA 547MB)은 별도 판단 ② 파이썬 의존 JS 교체(pypdf→pdfjs · hf CLI→직접 HTTPS) 추천안	이게 달해야 "설치 = 그날부터 LLM 사용"이 됨. 현재 배포본은 고객 기계에서 엔진·모델 받기가 막힘 (GIJO_AS_고객기계_실행환경_결정안_2026-08-10.md)
코드 서명 인증서	Windows SmartScreen 경고 제거	첫인상·설치 이탈
지식그 래프 ·LLM 위키	2026-08-10 도입 계획 수립(얇은 두 조각 추천안) — 만들어 둔 그래프를 검색이 쓰게	검색 품질·해자(후-6)
사업 결정 4건	파일럿 대상 선정 · 인증 예산·종류 · 가격 구조(라이선스+번들 구독) · 행동 대조 면책 문구 법무 검토	계획서 7절 — 코드 밖

7.7 진행 중인 제안 — 도메인 확장 증명

보안관제 도메인에서 매일 검증 중인 근거답변 골격(근거 게이트 · 안전한 보류 · 감사 · 평가 게이트)을 상담 도메인(취소·반품·교환)에 얹는 12주 PoC 제안을 준비 중입니다 — GS텔레서비스 AICC 「AI 데이터 HUB 및 정합성 검증 PoC」(초안 v0.5). 엔진을 새로 만드는 게 아니라 도메인 교체임을 증명하는 첫 사례입니다. → 상세: GIJO_AS_제안자료.md

8. 스크린샷 목록 (screenshots/ 폴더)

아래 12장은 실제 제품 화면을 실측 서버 응답 데이터로 렌더링한 것입니다(1440×960, 2배 해상도).

스크린샷은 2026-08-09 촬영(제품 5.12.0 시점) 화면입니다 — 업무 절차 5단계 허브·추가 기능 메뉴가 그대로 보입니다.

파일	화면	보이는 실측 데이터
01-보안KPI대시보드.png	보안 KPI	취약점 번다운·KEV·SLA + 자산·점검·CTI·KISA
02-CTI위협-자산매칭.png	위협 인텔리전스	매칭 4건 → 자산 3곳(근거 토큰)
03-AI자산-서비스영향도.png	AI 자산	서비스 3곳 모두 "영향도 높음"
deck/25-원격정기점검.png	원격 정기 점검	점검 거버넌스(운영 가이드에서 이관, 2026-08)
05-승인워크플로우.png	승인 워크플로우	finding 검토 게이트
06-헤르메스학습루프.png	헤르메스 학습 루프	수집→정제→학습→배포

파일	화면	보이는 실측 데이터
deck/21-설정-사용자관리.png	설정	모델 검색·받기·배정(추천 LLM 가이드에서 이관, 2026-08)
08-에이전트AI.png	에이전트 AI	8종 에이전트 카드
09-컴플라이언스.png	컴플라이언스	KISA 위협 21항목
10-AI-BOM-SBOM.png	AI-BOM	자산별 SBOM 생성/내보내기
11-취약자산관리-생애주기.png	취약 자산관리	Nessus 임포트·Critical 1(Log4Shell)·KEV·심각도 집계
12-보안제품관리-매뉴얼.png	보안제품 관리	종류별 4제품·제품/로그 매뉴얼·점검 연결

이 화면들은 제품 기본 상태에서 찍은 것입니다. **우리 환경의 실제 화면**이 필요하면 GIJO AS 앱에 로그인해 각 메뉴에서 직접 촬영하시면 됩니다.

문서 버전: **v5.15.0** · 데이터 기준일: 2026-08-10 · 수치는 실제 서버 구동 결과(자동화 시험 3,010개+ 통과 · 실패 0).
스크린샷은 2026-08-09 촬영분입니다(실측 데이터 렌더링 — 목업 아님).